

Лекция 3. Угрозы информационной безопасности телекоммуникационных систем

Учебные вопросы:

1. Понятие и классификация угроз информационной безопасности. Уязвимости информационной системы.
2. Атаки на информационную инфраструктуру. Классификация нарушителей информационной безопасности.

1. Понятие и классификация угроз информационной безопасности. Уязвимости информационной системы.

При построении системы защиты информации обязательно нужно определить, что следует защищать и от кого (или чего) следует строить защиту. Защищаться следует от множества угроз, которые проявляются через действия нарушителя. Угрозы возникают в случае наличия в системе уязвимостей, то есть таких свойств информационной системы, которые могут привести к нарушению информационной безопасности.



Определение перечня угроз и построение модели нарушителя являются обязательным этапом проектирования системы защиты. Для каждой системы перечень наиболее вероятных угроз безопасности, а также характеристика наиболее вероятного нарушителя индивидуальны, поэтому перечень и модель должны носить неформальный характер. Защищенность информации обеспечивается только при соответствии предполагаемых угроз и качеств нарушителя реальной обстановке. При наличии в системе уязвимости

потенциальная угроза безопасности может реализоваться в виде атаки. Атаки принято классифицировать в зависимости от целей, мотивов, используемого механизма, места в архитектуре системы и места нахождения нарушителя.

Для предупреждения успешных атак необходим поиск и анализ уязвимостей системы. Уязвимости различаются в зависимости от источника возникновения, степени риска, распространенности, места в жизненном цикле системы, соотношения с подсистемами защиты.

Любая **задача защиты информации** характеризуется, по крайней мере, четырьмя характеристиками, такими как **цель защиты**, **объект защиты**, **время защиты**, требуемая или максимально возможная **эффективность защиты**.

Цель защиты — это желаемый результат защиты, т.е. защиты от угроз и устранение уязвимостей.

Угроза безопасности информации — совокупность условий и факторов, создающих потенциальную или реально существующую опасность, связанную с утечкой информации и (или) несанкционированными и (или) непреднамеренными воздействиями на нее.

Для защищаемой системы составляют не полный перечень угроз, а перечень классов угроз, определяемых по ряду базовых признаков. Это связано с тем, что описать полное множество угроз невозможно из-за большого количества факторов, влияющих на информацию.

Классификация угроз ИБ по следующим признакам:



1. Природа возникновения: естественные угрозы (связанные с природными процессами) и искусственные (вызванные деятельностью человека).

2. Степень преднамеренности проявления: случайные или преднамеренные.

3. Источник угроз: природная среда, человек, санкционированные программно-аппаратные средства, несанкционированные программно-аппаратные средства.

4. Положение источника угроз: в пределах или вне контролируемой зоны.

5. Зависимость от активности системы: проявляются только в процессе обработки данных или в любое время.

6. Степень воздействия на систему: пассивные, активные (вносят изменения в структуру и содержание системы).

7. Этап доступа к ресурсам: на этапе доступа, после получения доступа.

8. Способ доступа к ресурсам: стандартный, нестандартный.

9. Место расположения информации: внешние носители, оперативная память, линии связи, устройства ввода-вывода.

Соответственно для информационных систем было предложено рассматривать три основных вида угроз рис.1:



Рис. 1 Основные виды угроз

1. *Угроза нарушения конфиденциальности* реализуется в том случае, если информация становится известной лицу, не располагающему полномочиями доступа к ней. Угроза нарушения конфиденциальности имеет место всякий раз, когда получен доступ к некоторой секретной информации, хранящейся в информационной системе или передаваемой от одной системы к другой. Иногда в связи с угрозой нарушения конфиденциальности используется термин «утечка».

2. *Угроза нарушения целостности* реализуется при несанкционированном изменении информации, хранящейся в информационной системе или передаваемой из одной системы в другую. Когда злоумышленники преднамеренно изменяют информацию, говорится, что целостность информации нарушена. Целостность также будет нарушена, если к несанкционированному изменению приводит случайная ошибка программного или аппаратного обеспечения.

3. *Угроза нарушения доступности (отказа служб)* реализуется, когда в результате преднамеренных действий, предпринимаемых другим пользователем или злоумышленником, блокируется доступ к некоторому ресурсу вычислительной системы. Блокирование может быть постоянным — запрашиваемый ресурс никогда не будет получен, или может вызывать только задержку запрашиваемого ресурса.

Уязвимость информационной системы — недостаток или слабое место в системном или прикладном программном (программно-аппаратном) обеспечении автоматизированной информационной системы, которые могут быть использованы для реализации угрозы безопасности информации.

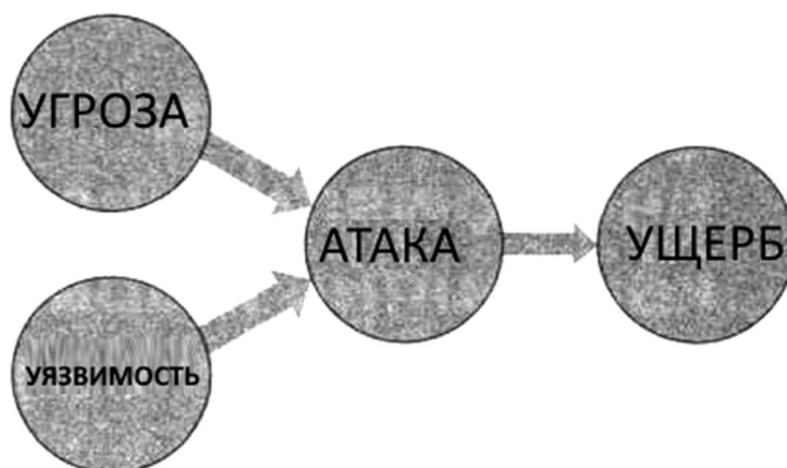


Рис.2 Этапы реализации атаки

2. Атаки на информационную инфраструктуру. Классификация нарушителей информационной безопасности.

Атака на информационную инфраструктуру – это действие, предпринятое злоумышленником, которое заключается в поиске и использовании той или иной уязвимости.

Основные виды атак:

1. *Вмешательство человека в работу АС.* К этому виду относятся организационные средства нарушения безопасности АС (кража носителей информации, несанкционированный доступ (НСД) к устройствам хранения и обработки информации, порча оборудования и т.д.) и осуществление нарушителем НСД к программным компонентам АС (все способы НСД в АС, а также способы получения нарушителем незаконных прав доступа к компонентам АС). Меры, противостоящие таким атакам, носят организационный характер (охрана, режим доступа к АС), а также включают в себя совершенствование систем обнаружения попыток атак (попыток подбора паролей).



2. Аппаратно - техническое вмешательство в работу АС. Т.е. нарушение безопасности и целостности информации в АС с помощью технических средств, например получение информации по электромагнитному излучению устройств АС. Защита от таких угроз, кроме организационных мер, предусматривает соответствующие аппаратные (экранирование излучений аппаратуры) и программные меры (шифрация).

3. Разрушающее воздействие на программные компоненты АС с помощью программных средств (разрушающих программных средств (РПС)). К ним относятся компьютерные вирусы, троянские кони, закладки, «логическая бомба», «часовая мина». Последний вид атак развивается более динамично, используя все последние достижения в области информационных достижений.

Нарушитель — это лицо, предпринявшее попытку выполнения запрещенных операций (действий) по ошибке, незнанию или осознанно со злым умыслом (из корыстных интересов) или без такового (ради игры или удовольствия, с целью самоутверждения и т. п.) и использующее для этого различные возможности, методы и средства.

Злоумышленник — нарушитель, намеренно идущий на нарушение из корыстных побуждений.

По отношению к системе нарушители могут быть внутренними (из числа персонала системы) или внешними (посторонними лицами).

Внутренним нарушителем может быть лицо из следующих категорий персонала:

- руководители различных уровней должностной иерархии;
- пользователи системы;
- сотрудники отделов разработки и сопровождения программного обеспечения;
- персонал, обслуживающий технические средства;

- технический персонал, обслуживающий здания (уборщики, электрики, сантехники и др.);
- сотрудники службы безопасности.

Внешние нарушители:

- клиенты;
- представители организаций, взаимодействующих по вопросам обеспечения жизнедеятельности организации (энерго-, водо-, теплоснабжения и т. п.);
- представители конкурирующих организаций (иностранных спецслужб) или лица, действующие по их заданию;
- лица, случайно или умышленно нарушившие пропускной режим (без цели нарушить безопасность);
- криминальные группировки;
- хакеры;
- любые лица за пределами контролируемой территории.

Классификация нарушителей

По уровню знаний о системе:

- 1) знание функциональных особенностей, основных закономерностей формирования в системе массивов данных и потоков запросов к ним, умение пользоваться штатными средствами;
- 2) обладание высоким уровнем знаний и опытом работы с техническими средствами системы, а также опытом их обслуживания;
- 3) обладание высоким уровнем знаний в области программирования и вычислительной техники, проектирования и эксплуатации автоматизированных информационных систем;
- 4) знание структуры, функций и механизмов действия средств защиты, их сильные и слабые стороны.

По уровню возможностей:

Первый уровень определяет самый низкий уровень возможностей ведения диалога: запуск задач (программ) из фиксированного набора,

реализующих заранее предусмотренные функции по обработке информации.

Второй уровень определяет возможность создания и запуска собственных программ с новыми функциями по обработке информации.

Третий уровень определяет возможность управления функционированием системы, т. е. воздействием на базовое программное обеспечение системы и на состав и конфигурацию ее оборудования.

Четвертый уровень определяет весь объем возможностей лиц, осуществляющих проектирование, реализацию и ремонт технических средств системы, вплоть до включения в состав собственных технических средств с новыми функциями по обработке информации. Классификация является иерархической, т. е. каждый следующий уровень включает в себя функциональные возможности предыдущего. В своем уровне нарушитель является специалистом высшей квалификации, знает все о информационной системе, в частности, о системе и средствах ее защиты.

По времени действия:

- в процессе функционирования (во время работы компонентов системы);
- в период неактивности компонентов системы (в нерабочее время, во время плановых перерывов в ее работе, перерывов для обслуживания и ремонта и т. п.);
- как в процессе функционирования, так и в период неактивности компонентов системы.

По месту действия:

- без доступа на контролируемую территорию организации;
- с контролируемой территории без доступа в здания и сооружения;

- внутри помещений, но без доступа к техническим средствам;
- с рабочих мест конечных пользователей (операторов);
- с доступом в зону данных (баз данных, архивов и т. п.);
- с доступом в зону управления средствами обеспечения безопасности.

Определение конкретных характеристик возможных нарушителей в значительной степени субъективно. Каждый вид нарушителя должен быть определен с помощью характеристик, приведенных выше.



Таким образом, обобщенный алгоритм воздействия угрозы (атаки) приведен на рисунке 3.

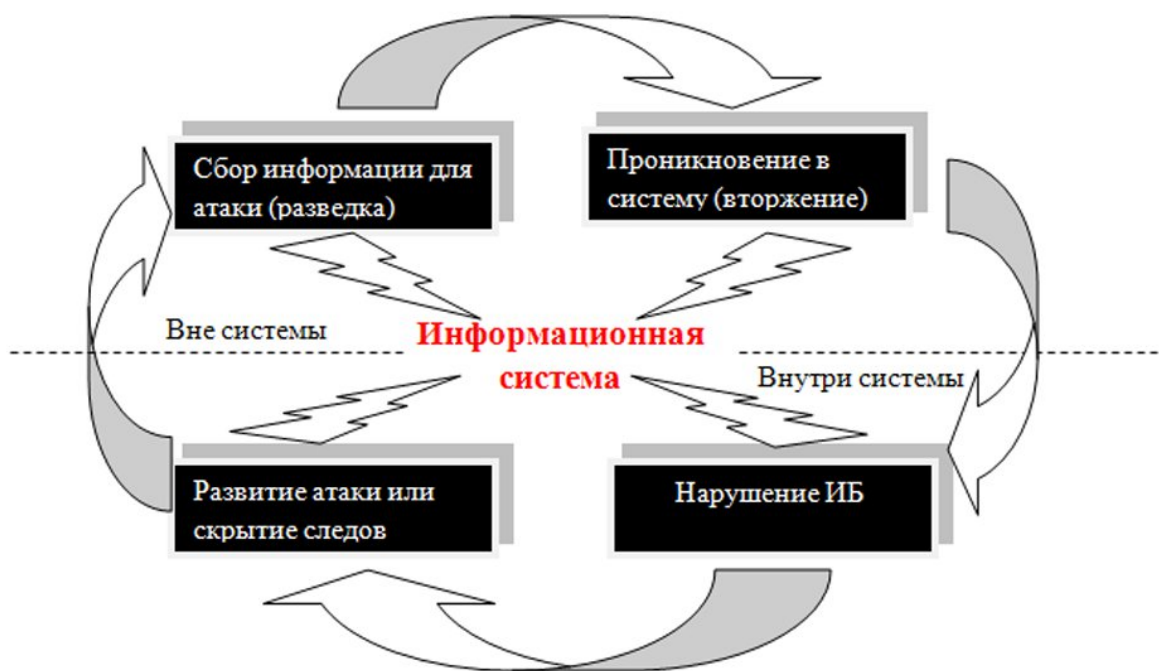


Рисунок 3. Обобщенный алгоритм воздействия угрозы (атаки).